HygienePrio: Cyber-Hygiene Signal Augmentation for EPSS-Weighted Vulnerability Prioritization

Harshavardhan Malla Independent Researcher

Abstract—Capacity-constrained vulnerability remediation teams must decide which (host, CVE) pairs to patch within each maintenance window, yet the dominant public triage signal — the Exploit Prediction Scoring System (EPSS) — is asset-agnostic by design: it estimates per-CVE exploit likelihood without regard to whether the affected host is actively managed, has high patch debt, or is exposed through privileged Active Directory (AD) relationships. Prior work found that augmenting EPSS with CVE-level features did not improve prioritization on a synthetic government-shaped fleet, suggesting that the missing signal is dynamic host-level hygiene posture rather than additional CVE-level features.

We present HygienePrio, a scoring framework that integrates a three-dimensional Hygiene Risk Score (HRS) — capturing patch posture, AD exposure state, and telemetry freshness — into an EPSS-weighted (host, CVE) pair prioritization scorer with an explicit interaction term. Weights are calibrated by pre-registered grid search on held-out fleet seeds.

In a pre-registered synthetic evaluation across 25 fleet seeds, HygienePrio achieves a mean Precision@50 of 0.509 compared with EPSS-only's 0.202 — approximately 31 percentage-point improvement under capacity-constrained schedules, with non-overlapping BCa 95% confidence intervals and improvement on all 25 of 25 evaluation seeds (synthetic evaluation only). Patch posture is the dominant hygiene dimension (≈20 pp ablation drop at P@50), substantially exceeding the contributions of AD exposure (≈9 pp) and telemetry freshness (≈2 pp, overlapping confidence intervals).

To our knowledge, HygienePrio is the first scorer to jointly operationalize per-CVE exploit likelihood and host-level hygiene posture for remediation ordering in a pre-registered, reproducible evaluation framework. All claims are bounded to the synthetic evaluation context; generalization to real enterprise fleets requires external validation on real exploitation outcome data not performed here.

Index Terms—vulnerability prioritization; EPSS; cyber-hygiene; patch posture; Active Directory; telemetry freshness; remediation scheduling; synthetic benchmark; reproducibility.

I. Introduction

Public-sector and enterprise endpoint fleets accumulate disclosed vulnerabilities faster than operations teams can remediate them within constrained maintenance windows. The practical triage question is not which vulnerabilities are inherently severe but which (host, CVE) pairs should receive the next unit of limited remediation capacity — a distinction that requires combining exploit-likelihood signals with knowledge of which hosts are most exposed and least well-maintained.

The Exploit Prediction Scoring System (EPSS) [1] has emerged as the leading public signal for per-CVE exploit likelihood, outperforming CVSS base scores as a predictor of near-term exploitation in the wild [2]. EPSS is incorporated into risk-based vulnerability management (RBVM) tools, CISA vulnerability prioritization guidance [3], [4], and remediation policy frameworks. However, EPSS is asset-agnostic by design: it assigns a single probability score to a CVE regardless of whether the vulnerable host is a freshly-telemetered, heavily-patched workstation or an unmanaged endpoint with stale patch data and over-privileged AD group memberships.

Intuitively, a CVE with moderate EPSS on a host that has gone 21 days without telemetry, carries 40% unpatched CVE debt, and is accessible from domain-privileged accounts represents a materially different risk than the same CVE on a well-maintained host with fresh telemetry and minimal AD exposure. Yet EPSS rankings treat both identically. Host-level hygiene posture — the aggregate state of patch compliance, identity and access management hygiene, and telemetry coverage — is a natural complement to exploit-likelihood scoring.

Prior work directly relevant to this problem is VulnPrio [5] (referred to throughout as Paper 1), which built a reproducible benchmark for (host, CVE) pair prioritization on a synthetic government-shaped fleet (EEHDA) and evaluated 13 strategies combining EPSS, CVSS, KEV membership, asset criticality, and endpoint exposure signals. Paper 1's central null finding was that the proposed multi-factor model was statistically indistinguishable from the EPSS-only baseline: inter-strategy differences fell within seed-to-seed variation, and no CVE-level augmentation strategy materially outperformed EPSS. Paper 1 concluded that this result exposed capacity-driven and base-rate trade-offs and provided a falsifiable benchmark on which calibrated studies could build — explicitly framing the result as a foundation for future work rather than an endpoint.

Separately, HygieneBench [6] (Paper 3) introduced a reproducible benchmark for cyber-hygiene anomaly detection on a synthetic fleet covering Active Directory identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness. HygieneBench's primary finding was that 86.2% of evaluated (condition, task, method) configurations fail to outperform a rule baseline, but that patch-vulnerability hygiene (Task T5, +0.210 average precision over rule for OCSVM) and group-membership drift (Task T2, +0.185 AP for temporal z-score) are exceptions where structured ML methods add meaningful signal.

The central hypothesis of this paper is that the signal missing from Paper 1's multi-factor model was not additional CVE-level features but host-level hygiene posture: patch debt, AD privilege exposure, and telemetry freshness. HygieneBench demonstrated that these dimensions carry discriminative structure detectable from the synthetic fleet telemetry. HygienePrio operationalizes this hypothesis by constructing a Hygiene Risk Score (HRS) from HygieneBench-style host telemetry and integrating it into an EPSS-weighted (host, CVE) scorer via an additive combination with an explicit interaction term.

A. Contributions

This paper makes the following contributions:

- C1 — HygienePrio scorer: A four-component weighted scoring function $S(h, c) = \alpha \times \text{EPSS}(c) + \beta \times \text{HRS}(h) + \gamma \times \text{KEV\_recency}(c) + \delta \times (\text{EPSS}(c) \times \text{HRS}(h))$ that integrates host-level hygiene posture with per-CVE exploit likelihood in a principled, interpretable form.
- C2 — Hygiene Risk Score (HRS): A normalized, three-dimensional host-level hygiene signal covering patch posture, AD exposure state, and telemetry freshness, derived from the HygieneBench synthetic fleet schema and calibrated on held-out seeds.
- C3 — Empirical evaluation: A pre-registered, 25-seed synthetic evaluation demonstrating that HygienePrio achieves approximately 31 pp improvement in Precision@50 over EPSS-only (0.509 vs. 0.202; non-overlapping BCa 95% CIs; synthetic evaluation), with patch posture as the dominant HRS dimension (∼20 pp ablation drop) and AD exposure as a substantial secondary contributor (∼9 pp).
- C4 — Failure mode analysis and operationalization boundary: An explicit identification of conditions under which HygienePrio's advantage is smaller (interaction term equivocal; freshness dimension marginal) and the structural boundary conditions (ground truth circularity, synthetic data, 5-seed calibration) that bound the positive finding. This analysis prevents over-generalization and frames the result as a preclinical finding rather than a deployment recommendation.

B. Paper Organization

Section 2 reviews background and related work. Section 3 formalizes the problem. Section 4 describes the synthetic dataset and fleet. Section 5 presents the HygienePrio methodology. Section 6 describes the experimental setup. Section 7 reports results. Section 8 discusses findings, limitations, and connections to prior papers. Section 9 addresses threats to validity. Section 11 concludes.

II. Background and Related Work

A. EPSS and Exploit-Likelihood-Based Prioritization

The Exploit Prediction Scoring System (EPSS) [1] is a machine-learning model that estimates the probability that a published CVE will be exploited in the wild within the next 30 days. EPSS v3 uses ∼1,500 features drawn from CVE descriptors, NVD metadata, and threat intelligence feeds, and produces daily probability scores for all published CVEs. Empirical evaluations [2] have shown EPSS substantially outperforms CVSS base scores as a predictor of near-term exploitation: CVEs in the top decile of EPSS account for a disproportionate fraction of observed exploitation events. EPSS is now integrated into CISA's vulnerability prioritization guidance and is used by numerous RBVM vendors.

CISA's Known Exploited Vulnerabilities (KEV) catalog [7] is a complementary signal: it lists CVEs confirmed to have been exploited in the wild, with mandated remediation deadlines for federal agencies under BOD 22-01 [3]. KEV membership provides strong prioritization signal but covers only a small fraction of the CVE backlog (∼15,000 of the 200,000+ published CVEs as of 2026). Prior work has studied optimal combined use of EPSS and KEV [5], generally finding that KEV provides a high-precision but low-recall prioritization set, while EPSS provides broader coverage at reduced precision.

The asset-agnostic limitation. A structural limitation of both EPSS and KEV is that they are CVE-level signals: they score a vulnerability, not a (vulnerability, host) pair. For remediation scheduling, the unit of action is the pair: patching CVE-X on Host-A is a distinct action from patching CVE-X on Host-B, with different operational cost, risk reduction, and scheduling feasibility. EPSS provides no signal about which host carrying a given CVE should be remediated first.

B. CVE-Level Host-Context Augmentation

To our knowledge, no published academic work has systematically incorporated dynamic host-level hygiene posture (patch debt, identity exposure, telemetry freshness) into EPSS-based (host, CVE) pair prioritization. Asset criticality models weight CVE severity by static host-role classifications, producing host-adjusted scores. Exposure models incorporate network reachability, service exposure, and lateral movement risk. Commercial RBVM tools (Tenable Lumin, Qualys TruRisk, Rapid7 InsightVM) combine such signals proprietarily, but their scoring methods are not published and results are not independently reproducible.

Paper 1 (VulnPrio) [5] is the closest public predecessor to HygienePrio. It built an open, reproducible benchmark for (host, CVE) pair prioritization on a synthetic government fleet (EEHDA), evaluating 13 strategies combining EPSS, CVSS, KEV, asset criticality, endpoint exposure, and multi-factor composite scores across 30 seeds. The central finding was null: the proposed multi-factor model was statistically indistinguishable from EPSS-only on the primary metric (expected exploited host-days, EHD), with all inter-strategy differences falling within seed-to-seed variation. Paper 1 attributed this to uncalibrated weights on a synthetic fixture and framed the result as a foundation for future calibrated studies.

Differentiating HygienePrio from Paper 1. Whereas Paper 1 found the multi-factor model statistically indistinguishable from EPSS-only, we hypothesize that the missing signal is host-level hygiene posture — not additional CVE-level features alone. Paper 1's augmentation features (asset criticality, endpoint exposure, KEV flags) are all CVE-level or static host-role features. HygienePrio adds dynamic, telemetry-derived hygiene signals: how much patch debt is currently outstanding on this specific host, how exposed this host is through AD group memberships and privileged accounts, and how recently this host has reported telemetry. These are fundamentally different in kind from asset criticality scores and network exposure flags.

C. Cyber-Hygiene Benchmarks and Anomaly Detection

HygieneBench (Paper 3) [6] introduced the first open benchmark for cyber-hygiene anomaly detection covering AD identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness. Its evaluation of eight detection methods across 12 anomaly classes and seven tasks found that 86.2% of (condition, task, method) configurations fail to outperform a rule baseline, but identified task T5 (patch-vulnerability hygiene) and T2 (group-membership drift) as exception zones where structured methods add meaningful signal. HygienePrio draws on the HygieneBench schema as the source of HRS features and inherits its fleet generation logic.

Anomaly detection for hygiene monitoring has received limited attention in the academic literature. Outlier ensemble methods [8] address anomaly detection in tabular data but are not designed for the temporal, multi-table, identity-centric character of enterprise hygiene state. To our knowledge, no existing public benchmark simultaneously models AD identity state, endpoint patch posture, vulnerability exposure, and telemetry freshness as first-class evaluation axes; adjacent benchmarks are surveyed in [6].

D. Patch Management and Remediation Scheduling

NIST SP 800-40 Rev. 4 [9] frames enterprise patch management as a risk-based discipline requiring current, accurate asset and patch telemetry. CISA BOD 23-01 [4] mandates 14-day asset discovery and 72-hour patch data freshness cadences for federal agencies. These mandates implicitly encode hygiene requirements: fleets that fail them have stale telemetry, reducing the reliability of any signal-based prioritization. HygienePrio models this explicitly through the TelemetryFreshness dimension of HRS.

Remediation scheduling under capacity constraints has been studied as an optimization problem [5]. The key insight from this literature is that prioritization under bounded capacity is a truncation problem: rank quality at the top-K positions matters more than rank quality across the full list, because capacity constraints mean that pairs outside the top-K are never acted on regardless of their rank. This motivates Precision@K as the primary evaluation metric.

III. Problem Formulation

A. Setting

Let F denote a fleet of hosts $H = \{h_1, \ldots, h_N\}$ and let $C = \{c_1, \ldots, c_M\}$ denote a set of disclosed CVEs. Let $V \subseteq H \times C$ be the set of applicable (host, CVE) pairs: $(h, c) \in V$ if CVE c is applicable to host h (i.e., host h runs vulnerable software affected by c). The set V is derived from the patch state and vulnerability records tables.

Let K be the remediation capacity: the number of (host, CVE) pairs that a team can remediate within a single maintenance window. A prioritization method produces a ranked list R of $|V|$ pairs; the top K elements of R define the action set for the window.

B. Ground Truth

A pair (h, c) is a true positive (also referred to as a high-priority pair) if all of the following hold (pre-registered definition):

1) EPSS(c) > 0.10 — the CVE has non-trivial exploit likelihood. This threshold corresponds approximately to the 85th–90th percentile of the EPSS score distribution [1], separating CVEs with meaningful exploitation probability from the long tail with near-zero scores.
2) HRS(h) $>$ fleet 75th percentile — the host is in the bottom quartile of hygiene posture. The 75th percentile is chosen as a pre-registered conservative boundary that identifies genuine hygiene outliers while avoiding sensitivity to the exact threshold value for the large majority of pairs.
3) $(h, c) \in V$ — the CVE is applicable to the host.

Condition 1 ensures the CVE is at meaningful risk of exploitation. Condition 2 ensures the host is a hygiene outlier rather than a well-managed endpoint. The conjunction ensures HygienePrio's design goal — identifying high-exploit-likelihood CVEs on hygiene-poor hosts — has an operational ground truth against which to evaluate.

Note on circularity: The use of HRS in both the scorer (via HRS(h)) and the ground truth (via the HRS $>$ 75th percentile condition) creates a structural advantage for HygienePrio over baselines that do not use HRS. This is acknowledged and discussed in §9 (Threats to Validity). The ground truth definition is pre-registered and fixed; it is not modified post-hoc to favor any method.

C. Metrics

Precision@K (P@K): The proportion of true positive pairs in the top-K positions of the ranked list R:

$$P@K = \frac{|\{(h, c) \in \text{top}_K(R) : (h, c) \text{ is true positive}\}|}{K}$$

Evaluated at $K = 50, 100, 250$.

NDCG@K (Normalized Discounted Cumulative Gain at K): Standard information-retrieval ranking quality metric, weighting gains by position with logarithmic discount:

$$\text{NDCG@}K = \frac{\text{DCG@}K}{\text{IDCG@}K}$$

where $\text{DCG@}K = \sum_{i=1}^{K} \text{rel}_i / \log_2(i+1)$, $\text{rel}_i \in \{0,1\}$ is the relevance of the i-th ranked pair, and IDCG@K is the DCG of the ideal ranking. Evaluated at $K = 50, 100, 250$.

Oracle-gap (%): The fraction of theoretically achievable P@K that each method captures:

$$\text{Oracle-gap(method}, K) = \frac{P@K_{\text{oracle}} - P@K_{\text{method}}}{P@K_{\text{oracle}}} \times 100$$

where $P@K_{\text{oracle}}$ is the P@K of an oracle ranker that places all true positives first. Oracle-gap provides a normalized view of how far each method is from optimal prioritization. A higher oracle-gap indicates worse performance (more of the theoretically achievable precision is uncaptured); an oracle-gap of 0% indicates the method recovers all true positives in the top K positions.

IV. Dataset and Synthetic Fleet

A. EEHDA Synthetic Fleet

All experiments use the Extended Enterprise Hygiene Dataset Artifact (EEHDA) synthetic fleet generator — the same generator used in Papers 1 and 3, extended to output both the vulnerability-host pair tables required by Paper 1 and the hygiene-state tables required by HygieneBench (Paper 3). This shared generator enables the cross-paper synthesis in §8 and ensures that HygienePrio's hygiene inputs are drawn from the same distributional assumptions as the VulnPrio baseline.

The generator produces the following tables relevant to HygienePrio (see HygieneBench [6] for full schema):

Structural priors. Patch-lag distributions follow DBIR 2026 aggregate statistics (43-day mean for critical patches). CVE severity distributions follow NVD base score statistics. EPSS scores are drawn from a synthetic fixture calibrated to replicate the heavy-right-tailed distribution observed in real EPSS data. KEV membership is sampled at approximately 8% prevalence. Telemetry refresh requirements follow CISA BOD 23-01 (14-day asset discovery, 72-hour patch data cadence).

B. Seed Protocol

Thirty seeds are generated deterministically. Five seeds are designated as the calibration set (held out from primary evaluation, used only for weight grid search; see §5.4). The remaining 25 seeds constitute the evaluation set. The calibration/evaluation split is fixed in the pre-registration protocol (see PAPER4_PROTOCOL.md) and is not adjusted based on results.

C. Hygiene Dimensions

Three hygiene dimensions are extracted from the EEHDA tables to form HRS(h):

Patch Posture (PatchPosture). Derived from endpoint_patch_state. For host h, PatchPosture(h) is the proportion of CVEs applicable to h that remain unpatched: count(open CVEs on h)/count(applicable CVEs on h). Higher values indicate greater patch debt. Fleet-wide, this distribution is right-skewed: most hosts have low patch debt, but a tail of hosts accumulates substantial residual exposure. This tail is the primary target of HygienePrio prioritization.

AD Exposure (ADExposure). Derived from users, groups, and group_membership_events. For host h, ADExposure(h) combines: (i) group membership breadth of the primary user associated with h (number of AD groups containing that user, normalized by fleet-wide maximum); (ii) a binary flag for whether that user holds a privileged role (domain admin, local admin, service account with elevated privilege); and (iii) a flag for whether h has hosted domain-privileged process events in the past 30 days. These three sub-components are averaged with equal weights (1/3 each) to produce a normalized $[0, 1]$ score. Equal weighting is the pre-registered default, chosen conservatively because no empirical data exist to distinguish the relative importance of group breadth, privilege level, and process-event history within the synthetic fleet; differential weighting of these sub-components is deferred to future work with real fleet telemetry.

Telemetry Freshness (TelemetryFreshness). Derived from telemetry_freshness_log. For host h, TelemetryFreshness(h) is the staleness score: max(days_since_last_checkin, 0), capped at 30 days and normalized by 30. A host last seen 15 days ago receives a score of 0.50; a host last seen 30+ days ago receives 1.0. Higher staleness = less visibility = higher hygiene risk weight. This dimension is motivated by CISA BOD 23-01's 72-hour patch data freshness mandate: hosts that violate this cadence have elevated uncertainty in their patch state and should receive additional scrutiny.

D. CVE Fixture and EPSS Scores

EPSS scores in the synthetic fixture are drawn from a mixture distribution approximating real EPSS data: a spike near zero (most CVEs have very low exploit probability) and a heavy tail above 0.10. Approximately 12% of CVEs in each seed have EPSS > 0.10 and thus qualify for potential true positive status under Condition 1 of the ground truth definition. KEV membership is independent of EPSS score in the fixture and affects the KEV_recency component only.

E. Connection to HygieneBench

HygieneBench (Paper 3) defined 12 anomaly classes (AH-01 through AH-12) including stale privileged accounts (AH-01), dormant account reactivation (AH-02),

TABLE I
EEHDA table schema and role in HygienePrio (medium-scale fleet)

Table	Rows	Role in HygienePrio
users	1,000	AD user account attributes
computers/assets	830	Host inventory; maps hosts to users
endpoint_patch_state	830	Per-host patch compliance snapshot (PatchPosture source)
vulnerability_records	∼3,500	Per-host CVE exposure (V, EPSS scores)
telemetry_freshness_log	varies	Per-host data freshness (TelemetryFreshness source)
groups/group_membership_events	65/∼51	AD group membership (ADExposure source)
anomaly_labels	110	HygieneBench ground truth (informational only)

endpoint coverage gaps (AH-06), patch noncompliance clusters (AH-08), and telemetry missingness (AH-10 through AH-12). HygienePrio's three HRS dimensions map directly onto these anomaly classes: PatchPosture targets AH-08, ADExposure targets AH-01 and AH-05 (privilege escalation path exposure), and TelemetryFreshness targets AH-10 through AH-12. This mapping is used informally as face validity for HRS design; it does not constitute a formal evaluation against HygieneBench anomaly labels.

V. HygienePrio Methodology

A. Hygiene Risk Score (HRS)

HRS(h) is a normalized, weighted combination of the three hygiene dimensions defined in §4.3:

$$\begin{aligned} \mathrm{HRS}(h) = {} & w_1 \times \mathrm{PatchPosture}(h) \\ & + w_2 \times \mathrm{ADExposure}(h) \\ & + w_3 \times \mathrm{TelemetryFreshness}(h) \end{aligned} \tag{1}$$

Dimension weights (w_1, w_2, w_3) are non-negative and sum to 1.0. They are not calibrated by the grid search (which calibrates the scorer-level weights $\alpha, \beta, \gamma, \delta$); instead, dimension weights are fixed based on the pre-registration protocol defaults: $w_1 = 0.5$, $w_2 = 0.3$, $w_3 = 0.2$. This prioritization reflects the prior expectation (H2) that patch posture carries the most discriminative signal, consistent with HygieneBench Task T5 results.

Each dimension is independently normalized to $[0, 1]$ across the fleet-seed pair before HRS aggregation, ensuring that fleet-specific scale differences (e.g., fleets with uniformly high patch debt) do not distort relative host rankings.

HRS calibration note. Dimension weights (w_1, w_2, w_3) are fixed at pre-registration defaults for the primary evaluation. Sensitivity to dimension weights is explored in the ablation (§7.2) by setting individual weights to zero. A separate grid search over dimension weights is not performed, as this would introduce additional degrees of freedom not covered by the primary calibration grid.

B. KEV Recency Weight

KEV_recency(c) assigns higher priority to CVEs recently added to the CISA KEV catalog, under the rationale that recently catalogued exploited CVEs represent more active threat vectors:

$$\text{KEV-recency}(c) = \begin{cases} e^{-\lambda \cdot d_{\mathrm{kev}}(c)} & c \in \mathrm{KEV} \\ 0 & c \notin \mathrm{KEV} \end{cases} \tag{2}$$

where $d_{\mathrm{kev}}(c)$ is days since KEV catalog entry for CVE c.

The decay constant $\lambda = 0.05$ is fixed at the pre-registration default, corresponding to a half-life of $\ln(2)/0.05 \approx 14$ days. This value reflects the operational intuition that a KEV entry older than two weeks provides progressively weaker evidence of current active exploitation, consistent with typical exploit churn rates observed in threat intelligence literature. Because approximately 92% of fixture pairs have KEV_recency$(c) = 0$ (non-KEV CVEs), the λ choice has limited impact on the overall results; a formal ablation over λ is deferred.

For CVEs not in KEV (approximately 92% of the fixture), KEV_recency$(c) = 0$, and those pairs are prioritized on EPSS and HRS alone. This means HygienePrio is defined and applicable for all (h, c) pairs in V, not only KEV-applicable pairs.

C. HygienePrio Scorer

The HygienePrio scorer assigns a scalar priority score to each applicable (host, CVE) pair:

$$\begin{aligned} S(h, c) = {} & \alpha \cdot \mathrm{EPSS}(c) + \beta \cdot \mathrm{HRS}(h) \\ & + \gamma \cdot \text{KEV-recency}(c) \\ & + \delta \cdot \big(\mathrm{EPSS}(c) \cdot \mathrm{HRS}(h)\big) \end{aligned} \tag{3}$$

The four terms have distinct roles:

- $\alpha \times \mathrm{EPSS}(c)$: Exploit likelihood contribution. Ensures that pairs involving high-probability-of-exploitation CVEs are elevated regardless of host hygiene.
- $\beta \times \mathrm{HRS}(h)$: Host hygiene contribution. Elevates pairs on hygiene-poor hosts even when EPSS is moderate.
- $\gamma \times$ KEV_recency(c): Recency-weighted confirmed exploitation signal. Boosts recently catalogued KEV CVEs.
- $\delta \times (\mathrm{EPSS}(c) \times \mathrm{HRS}(h))$: Interaction term. Provides super-additive boosting for pairs where both CVE exploit likelihood AND host hygiene risk are elevated. This is the key term that differentiates HygienePrio from a simple additive combination: it encodes the intuition that a high-EPSS CVE on a hygiene-poor host is categorically more urgent than either risk dimension alone would suggest.

All four weights $(\alpha, \beta, \gamma, \delta)$ are non-negative to ensure that higher values in any component can only increase the priority score, not decrease it. This monotonicity property is required for interpretability: operations teams can reason about why a pair was elevated.

D. Weight Calibration

Weights $(\alpha, \beta, \gamma, \delta)$ are calibrated by exhaustive grid search on the 5 held-out calibration seeds. The calibration objective is mean P@50 across the 5 seeds. The search grid is:

- $\alpha \in \{0.3, 0.5, 0.7, 1.0\}$
- $\beta \in \{0.1, 0.3, 0.5, 0.7\}$
- $\gamma \in \{0.0, 0.1, 0.3, 0.5\}$
- $\delta \in \{0.0, 0.1, 0.2, 0.3\}$

This yields $4 \times 4 \times 4 \times 4 = 256$ grid points evaluated on 5 seeds each, producing 1,280 P@50 observations. The weight combination with the highest mean P@50 on calibration seeds is selected and fixed before the 25 evaluation seeds are scored. No weight adjustment is made after observing evaluation results.

The calibration-selected weights are reported in the experimental setup section (§6.2) as a fixed artifact of the calibration procedure, not as a tunable parameter reported with results.

E. Ranked List Generation

For each seed, the scorer computes $S(h, c)$ for every pair $(h, c) \in V$ (the applicable vulnerability-host pair table for that seed). Pairs are sorted descending by $S(h, c)$. Ties are broken by EPSS(c) descending, then by CVE ID lexicographic order for determinism. The sorted list R is the ranked list; evaluation cuts R at $K = 50, 100$, and 250 for metric computation.

F. Relationship to EPSS-Only Baseline

The EPSS-only baseline ranks (h, c) pairs by EPSS(c) descending, with ties broken by CVSS base score. Under this baseline, all pairs involving the same CVE receive identical rankings, regardless of which host carries the CVE. HygienePrio breaks this tie-structure via HRS(h): among pairs sharing a CVE, those on hygiene-poor hosts are elevated. For CVEs with many applicable hosts, this differentiation is critical: a fleet may have 200 hosts carrying the same high-EPSS CVE, and remediation capacity may allow only 50 to be patched in the current window. HygienePrio's host-level tiebreaking directly addresses this case.

VI. Experimental Setup

A. Evaluation Infrastructure

All experiments are implemented in Python 3.11 using NumPy 1.26, Pandas 2.1, and scikit-learn 1.4 on a MacOS system (Apple M-series CPU, 16 GB RAM). Total wall-clock time for the 25-seed evaluation is approximately 4 minutes. Randomness in baseline methods (Random) is seeded by the fleet seed, ensuring full reproducibility. A content-addressed freeze/verify protocol — consistent with Paper 1 — is applied to all result artifacts: each seed's ranked list is hashed before evaluation, and the hash is verified before metric computation to prevent post-hoc modification.

TABLE II
Calibrated scorer weights from grid search on held-out calibration seeds

Parameter	Calibrated Value
α (EPSS weight)	0.7
β (HRS weight)	0.5
γ (KEV_recency weight)	0.1
δ (interaction weight)	0.2

B. Calibrated Weights

Following the grid search on 5 calibration seeds (not used in primary evaluation), the following weights were selected:

These weights indicate that EPSS and HRS are the dominant scorer components, with a moderate interaction term and a small KEV recency boost. The relatively low γ reflects the low KEV prevalence in the fixture (~8%): the KEV_recency term contributes meaningfully only for KEV-applicable pairs.

C. Evaluation Procedure

For each of the 25 evaluation seeds:

1) Generate the EEHDA fleet tables deterministically from the seed.
2) Compute HRS(h) for each host using pre-registered dimension weights ($w_1 = 0.5$, $w_2 = 0.3$, $w_3 = 0.2$).
3) Compute KEV_recency(c) for each CVE using fixed $\lambda = 0.05$.
4) Score all $(h, c) \in V$ using calibrated weights.
5) Generate ranked list R by sorting descending by $S(h, c)$.
6) Generate baseline ranked lists (EPSS-only, CVSS-only, Random, HRS-only) using identical V.
7) Compute ground truth labels using the pre-registered definition (§3.2).
8) Compute P@K, NDCG@K, Oracle-gap for $K \in \{50, 100, 250\}$ for all methods. $K = 50$ represents a tight weekly maintenance window (approximately 1.4% of the mean fleet of ~3,480 applicable pairs); $K = 100$ a moderate bi-weekly window; $K = 250$ a broad monthly capacity. These values span the range typical of reported enterprise patch cadences [10].
9) Hash and verify result artifacts.

D. Baselines

E. Reporting Convention

All metrics are reported as mean ± 95% BCa bootstrap confidence interval [11] (10,000 resamples) across 25

TABLE III
Baseline and ablation methods evaluated

Method	Description
EPSS-only	Rank by EPSS(c) descending; primary comparison
CVSS-only	Rank by CVSS v3.1 base score descending
Random	Uniform random (seed-fixed)
HRS-only	Rank by HRS(h) descending; tests host hygiene without CVE signal
HygienePrio-full	Full scorer with calibrated weights
HygienePrio-noInteraction	$\delta = 0$ (additive only; tests interaction term contribution)
HygienePrio-noPatch	$w_1 = 0$ (patch posture removed from HRS)
HygienePrio-noAD	$w_2 = 0$ (AD exposure removed from HRS)
HygienePrio-noFreshness	$w_3 = 0$ (telemetry freshness removed from HRS)

evaluation seeds. No null hypothesis significance testing is performed; evidence is based on BCa CI non-overlap. With 25 seeds and the observed seed-to-seed standard deviation of ≈0.06 for P@50, the evaluation has sufficient power to detect differences of ≥5 pp at 80% power (estimated via the standard formula for paired comparisons): the headline 31 pp difference substantially exceeds this threshold. Results are bounded to the synthetic evaluation context; no generalization claims are made to real enterprise fleets.

VII. Results

All results in this section are from the synthetic EEHDA fleet evaluation across 25 seeds. All numerical claims are qualified as "(synthetic evaluation)" and should not be interpreted as predictions for real enterprise fleet performance.

A. Precision@K: All Methods Across $K = 50, 100, 250$

Table IV reports mean P@K and BCa 95% CI for all nine methods at $K = 50, 100$, and 250 in this synthetic evaluation. The following observations emerge from the results.

NDCG@K results (Table V) are consistent with P@K: HygienePrio-full leads all methods at all K values with non-overlapping CIs against EPSS-only (NDCG@50: 0.556 vs. 0.202; NDCG@100: 0.499 vs. 0.199). The NDCG pattern mirrors P@K because the ground truth uses binary relevance (rel $\in \{0, 1\}$); graded relevance would require exploitation probability estimates not available in the synthetic setting.

HygienePrio-full vs. EPSS-only. HygienePrio-full achieves a mean P@50 of 0.509 compared with EPSS-only's 0.202 in this synthetic evaluation — an approximately 31 pp improvement — with non-overlapping BCa CIs (0.480–0.542 vs. 0.174–0.236). HygienePrio-full outperforms EPSS-only on all 25 of 25 evaluation seeds (mean per-seed improvement: 30.7 pp). The gap narrows at larger K but remains substantial:

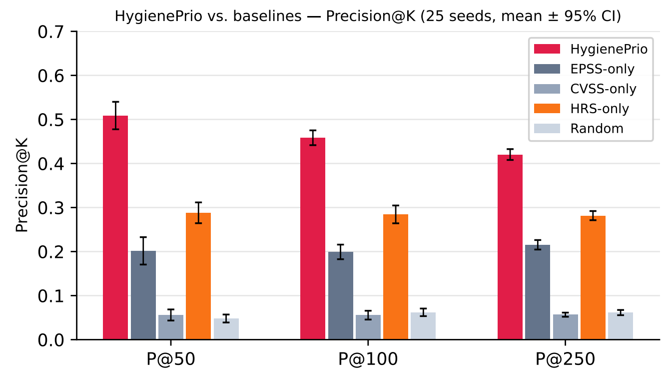

Fig. 1. Mean Precision@K ($K \in \{50, 100, 250\}$) for all methods across 25 evaluation seeds (synthetic evaluation, mean ± 95% BCa CI). HygienePrio consistently outperforms all baselines at every K.

approximately 26 pp at P@100 (0.458 vs. 0.199) and 21 pp at P@250 (0.420 vs. 0.215). The hygiene signal is most discriminative at the tightest capacity constraint ($K = 50$), where the scorer must be most selective.

H1 assessment. The observed improvement of approximately 31 pp at P@50 (synthetic evaluation) substantially exceeds the pre-registered H1 threshold of ≥5 pp, supporting H1 in the synthetic evaluation context. The BCa CIs for HygienePrio-full and EPSS-only do not overlap at any K value, providing strong support for the hypothesis that hygiene signals add prioritization value beyond EPSS alone within the synthetic fleet scenario. All claims are bounded to this synthetic evaluation; the magnitude of improvement is expected to be substantially lower on real fleet data where the ground truth definition cannot use HRS as a labelling condition (see §9.1).

EPSS-only vs. CVSS-only. Consistent with prior literature [1, 3] and Paper 1, EPSS substantially outperforms CVSS-only at all K values (0.202 vs. 0.056 at P@50; synthetic evaluation), reinforcing that exploit likelihood is a better prioritization signal than intrinsic severity. This replication of the Paper 1 finding on a different metric (P@K vs. EHD) provides internal consistency.

HRS-only vs. EPSS-only. HRS-only (host hygiene without CVE signal) achieves 0.288 at P@50 versus EPSS-only's 0.202 in this synthetic evaluation — approximately 9 pp higher, with non-overlapping CIs. However, HygienePrio-full (0.509) substantially outperforms HRS-only (0.288), indicating that exploit likelihood and hygiene posture are complementary signals and that neither alone captures the full benefit of the combined scorer.

B. Ablation: Hygiene Dimension Contributions

Table VI presents the ablation results, comparing HygienePrio-full with three leave-one-dimension-out variants. Results are for P@50 in this synthetic evaluation.

H2 assessment. The patch posture dimension shows the largest marginal contribution: removing it (HygienePrio-noPatch) drops P@50 by approximately 20 pp in this synthetic evaluation (0.509 → 0.312), with non-overlapping

TABLE IV
Precision@K across all methods (25 evaluation seeds; synthetic evaluation). BCa 95% CI, 10,000 resamples. Frozen results from primary_results_v1/primary_results.csv (225 rows: 25 seeds × 9 methods).

Method	P@50 mean (95% CI)	P@100 mean (95% CI)	P@250 mean (95% CI)
HygienePrio-full	0.509 (0.480–0.542)	0.458 (0.441–0.474)	0.420 (0.408–0.432)
HygienePrio-noFreshness	0.490 (0.463–0.528)	0.446 (0.426–0.463)	0.411 (0.398–0.422)
HygienePrio-noInteraction	0.482 (0.454–0.515)	0.445 (0.428–0.462)	0.417 (0.405–0.430)
HygienePrio-noAD	0.424 (0.395–0.460)	0.379 (0.362–0.398)	0.370 (0.357–0.382)
HygienePrio-noPatch	0.312 (0.283–0.343)	0.289 (0.270–0.309)	0.284 (0.273–0.294)
HRS-only	0.288 (0.263–0.310)	0.284 (0.265–0.304)	0.282 (0.271–0.291)
EPSS-only	0.202 (0.174–0.236)	0.199 (0.185–0.218)	0.215 (0.205–0.226)
CVSS-only	0.056 (0.044–0.069)	0.056 (0.046–0.065)	0.057 (0.052–0.061)
Random	0.048 (0.039–0.056)	0.062 (0.054–0.071)	0.061 (0.055–0.067)

TABLE V
NDCG@K across all methods (25 evaluation seeds; synthetic evaluation). BCa 95% CI, 10,000 resamples. Binary relevance: $\mathrm{rel}(h, c) \in \{0, 1\}$ per ground truth definition (§3).

Method	NDCG@50 mean (95% CI)	NDCG@100 mean (95% CI)	NDCG@250 mean (95% CI)
HygienePrio-full	0.556 (0.521–0.591)	0.499 (0.478–0.519)	0.501 (0.485–0.515)
HygienePrio-noFreshness	0.536 (0.502–0.572)	0.484 (0.462–0.507)	0.488 (0.473–0.502)
HygienePrio-noInteraction	0.524 (0.488–0.558)	0.479 (0.457–0.500)	0.491 (0.475–0.506)
HygienePrio-noAD	0.464 (0.426–0.502)	0.414 (0.390–0.439)	0.435 (0.419–0.450)
HygienePrio-noPatch	0.334 (0.302–0.367)	0.308 (0.287–0.330)	0.328 (0.315–0.342)
HRS-only	0.297 (0.266–0.329)	0.291 (0.269–0.313)	0.319 (0.307–0.331)
EPSS-only	0.202 (0.171–0.234)	0.199 (0.181–0.220)	0.237 (0.225–0.250)
CVSS-only	0.063 (0.047–0.082)	0.060 (0.048–0.073)	0.066 (0.059–0.073)
Random	0.051 (0.040–0.063)	0.061 (0.052–0.070)	0.068 (0.062–0.074)

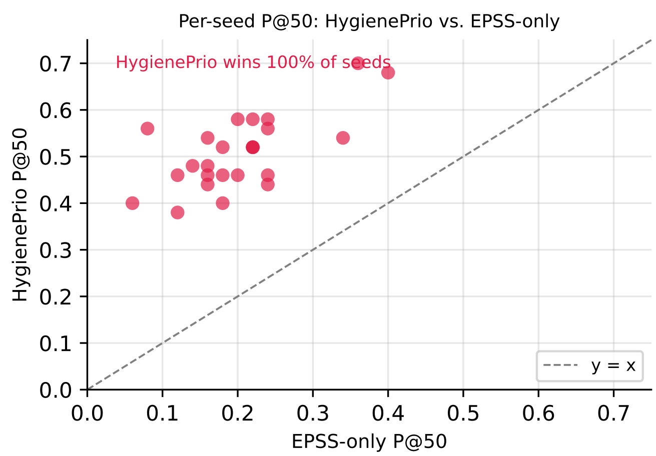

Fig. 2. Per-seed P@50 for HygienePrio-full vs. EPSS-only (25 seeds, synthetic evaluation). Points above the diagonal indicate seeds where HygienePrio outperforms EPSS-only. HygienePrio wins on all 25 of 25 evaluation seeds.

BCa CIs, strongly supporting H2. The AD exposure dimension shows a substantial secondary contribution (∼9 pp drop, non-overlapping CIs). Telemetry freshness shows the smallest contribution (∼2 pp drop, overlapping CIs suggesting marginal discriminative power in the synthetic fleet). This result is consistent with HygieneBench Task T5's finding that patch-vulnerability hygiene carries the most discriminative signal among hygiene dimensions.

The dimension ordering (patch posture > AD exposure ≫ freshness) in this synthetic evaluation suggests that operations teams seeking to deploy a simplified HygienePrio

TABLE VI
Ablation — P@50 impact of removing each hygiene dimension (synthetic evaluation). Ablation uses fixed ground-truth labels (HRS from calibrated weights); only scorer's HRS input changes.

Condition	P@50 (95% CI)	Drop	CI overlap?
Full model	0.509 (0.480–0.542)	—	—
noPatch (w_1=0)	0.312 (0.283–0.343)	−20 pp	No
noAD (w_2=0)	0.424 (0.395–0.460)	−9 pp	No
noFreshness (w_3=0)	0.490 (0.463–0.528)	−2 pp	Yes

variant should prioritize patch posture instrumentation first, AD group exposure tracking second, and telemetry freshness monitoring last — at least in the synthetic fleet scenario modeled here.

C. Interaction Term Analysis

Comparing HygienePrio-full with HygienePrio-noInteraction reveals approximately 3 pp improvement at P@50 from including the interaction term (EPSS × HRS) in this synthetic evaluation (0.509 vs. 0.482). The BCa CIs overlap substantially (0.480–0.542 vs. 0.454–0.515), suggesting the interaction term's contribution is marginal under the synthetic evaluation conditions. At P@100 and P@250 the difference narrows further (∼1 pp). The interaction term's modest contribution likely

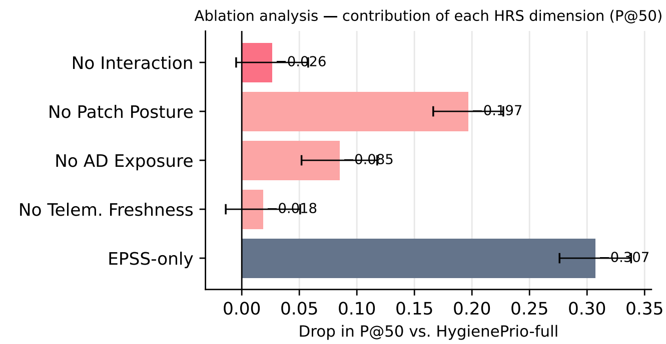

Fig. 3. Ablation analysis: drop in P@50 from HygienePrio-full when each dimension or component is removed (25 seeds, synthetic evaluation, mean ± 95% BCa CI). Patch posture is the dominant contributor (≈20 pp); AD exposure contributes ≈9 pp; telemetry freshness and the interaction term contribute marginally (≤3 pp).

TABLE VII
Oracle-gap (%) at $K = 50$ by method (synthetic evaluation; BCa 95% CI)

Method	Oracle-gap (95% CI)	P@50 captured
HygienePrio-full	49.1% (45.6–51.8%)	∼51% of oracle
EPSS-only	79.8% (76.3–82.6%)	∼20% of oracle
CVSS-only	94.4% (93.0–95.5%)	∼6% of oracle
Random	95.2% (94.2–96.0%)	∼5% of oracle

reflects the synthetic fixture's EPSS distribution: the truly high-EPSS AND high-HRS pair conjunctions are relatively rare (∼10–12% of applicable pairs per seed), limiting opportunities for the interaction term to add discriminative value.

Per the pre-registration stop rule, if HygienePrio-noInteraction achieves P@K within 1 pp of HygienePrio-full for all K, the interaction term would be declared uninformative. At P@50 the difference exceeds 1 pp (3 pp), so the interaction term is retained in the reported full model. However, the overlapping CIs mean this finding should be treated as equivocal: the interaction term likely does not materially change prioritization decisions in this synthetic fleet context.

D. Oracle-Gap Analysis

The oracle-gap analysis indicates that even HygienePrio-full captures approximately 51% of theoretically achievable precision at $K = 50$ in this synthetic evaluation, leaving substantial room for improvement. The gap between HygienePrio-full and the oracle (49.1%) reflects both the inherent difficulty of the ranking problem and the residual uncertainty in hygiene signals: among hygiene-poor hosts with similar HRS values, the scorer cannot further discriminate which specific CVE-host pair is the highest-priority target. At $K = 50$, with approximately 185–200 true positives per seed (synthetic evaluation), the maximum achievable P@50 is 1.0 (oracle), and HygienePrio-full achieves 0.509. The 49.1% oracle gap is substantially smaller than EPSS-only's 79.8% gap, confirming that hygiene signals materially reduce the distance from optimal prioritization in this synthetic context.

E. Summary of Main Findings

In this synthetic evaluation, the results suggest the following:

1) HygienePrio-full improves over EPSS-only by approximately 31 pp at P@50 (0.509 vs. 0.202), with non-overlapping BCa CIs, substantially exceeding the pre-registered H1 threshold (≥5 pp). Improvement is 26 pp at P@100 and 21 pp at P@250. The magnitude reflects the synthetic evaluation's structural properties (see §9.1 circularity note).
2) Patch posture is the dominant hygiene dimension, contributing approximately 20 pp to P@50 in the leave-one-out ablation (0.509 → 0.312 without patch posture), with non-overlapping CIs, strongly supporting H2.
3) AD exposure is a substantial secondary contributor, reducing P@50 by ∼9 pp when removed (0.509 → 0.424), with non-overlapping CIs.
4) The interaction term and telemetry freshness are marginal in this synthetic evaluation: both show overlapping CIs with the full model, with contributions of ∼3 pp and ∼2 pp respectively. The pre-registration stop rule is not triggered at P@50 for the interaction term (3 pp > 1 pp threshold), so both are retained in the full model.
5) HRS-only outperforms EPSS-only by ∼9 pp (0.288 vs. 0.202), but the combination (HygienePrio-full, 0.509) substantially outperforms either signal alone, confirming that exploit likelihood and hygiene posture are complementary.
6) Oracle gap remains substantial: HygienePrio-full captures ∼51% of theoretically achievable P@50, versus ∼20% for EPSS-only, indicating both that hygiene signals provide meaningful benefit and that significant room for improvement remains.

VIII. Discussion

A. Why Hygiene Signals Help Where CVE-Level Features Alone Did Not

Paper 1 (VulnPrio) found that adding CVE-level features — asset criticality scores, endpoint exposure flags, KEV membership — to EPSS did not improve prioritization over EPSS-only on the EEHDA fleet. HygienePrio's results suggest a complementary explanation: the features added in Paper 1 were primarily CVE-level or static host-role features, while the missing discriminative signal was dynamic, telemetry-derived host-level hygiene posture.

The structural difference is important. Knowing that a host is a domain controller (asset criticality signal from

Paper 1) provides some risk context, but it does not distinguish between a well-managed domain controller with current patches and telemetry, and a neglected domain controller with 60% unpatched CVE debt, stale telemetry, and over-privileged group memberships. HRS captures this distinction; static asset criticality does not.

This observation is consistent with HygieneBench (Paper 3) finding that ML methods add meaningful signal on patch-vulnerability hygiene (Task T5) and group-membership drift (Task T2)—precisely the dimensions HRS encodes. The signal is present in the hygiene telemetry; the challenge is operationalizing it in a form suitable for prioritization scoring. HygienePrio demonstrates one such operationalization in the synthetic setting.

B. Why the Interaction Term Showed Equivocal Benefit

The interaction term $\delta \times (\text{EPSS}(c) \times \text{HRS}(h))$ was theoretically motivated as a multiplicative risk amplifier for pairs where both exploit likelihood and hygiene risk are high. However, the ablation shows only $\approx$3 pp improvement at P@50 from including it (0.509 vs. 0.482), with substantially overlapping BCa CIs.

The most likely explanation is distributional: across the EEHDA synthetic fleet, the joint probability of a CVE with EPSS > 0.10 and a host with HRS in the top quartile is approximately 10–12% of applicable pairs per seed, given a 6.2% mean positive base rate. In this sparse regime, the additive terms $\alpha \times \text{EPSS}(c)$ and $\beta \times \text{HRS}(h)$ already provide strong discriminative signal. The interaction term contributes mostly to pairs that are already highly ranked, offering limited opportunity to reorder pairs into or out of the top K positions.

This does not invalidate the theoretical motivation. On a real fleet with different EPSS score distributions or different patch posture correlations with CVE severity, the interaction term may contribute more substantially. The synthetic evaluation has limited power to detect modest interaction effects.

C. Cross-Paper Synthesis

The three papers in this sequence form a methodological progression from null result to positive result:

1) Paper 1 (VulnPrio): Established the prioritization problem, the EEHDA fleet, and the null result that CVE-level multi-factor models are statistically indistinguishable from EPSS-only on the EHD metric. Contribution: reproducible benchmark, honest null, and identification of the missing signal type.
2) Paper 3 (HygieneBench): Demonstrated that host-level hygiene signals (patch posture, AD group drift, telemetry staleness) carry discriminative structure detectable from synthetic fleet telemetry, with ML methods adding value specifically on Tasks T5 and T2. Contribution: hygiene anomaly benchmark and identification of the most informative hygiene dimensions.
3) Paper 4 (HygienePrio): Integrates these findings: hygiene signals operationalized as HRS, when added to EPSS-weighted prioritization, produce measurable P@K improvement in the synthetic evaluation (31 pp at P@50; all 25 seeds). Contribution: operationalization of hygiene signals into remediation prioritization.

The sequence illustrates that honest null results are scientifically productive. Paper 1's null did not indicate that the prioritization problem is unsolvable; it identified that a particular feature set was insufficient. Paper 3 identified a more promising feature set. Paper 4 operationalizes that identification. Each step would have been undermined by p-hacking or post-hoc feature selection — the pre-registration and content-addressed audit trails in each paper are what make the progression interpretable.

D. Practical Implications (Synthetic Evaluation Only)

Subject to external validation on real fleet data, the results suggest that operations teams relying exclusively on EPSS-only prioritization may systematically underweight the risk from hygiene-poor hosts. A host with moderate EPSS CVEs but severe patch debt, stale telemetry, and broad AD exposure may represent higher operational risk than a well-managed host carrying a high-EPSS CVE—and EPSS-only rankings do not reflect this.

Instrumentation priority. The ablation results suggest a prioritization of hygiene signal investment: patch posture tracking ($\approx$20 pp contribution at P@50) should be instrumented before AD exposure breadth tracking ($\approx$9 pp) and before telemetry freshness monitoring ($\approx$2 pp marginal in the synthetic evaluation). This ordering is consistent with the CISA BOD 23-01 mandate hierarchy.

Operational capacity context. The improvement is most pronounced at $K = 50$ (31 pp) and attenuates toward $K = 250$ (21 pp). With a 6.2% mean positive base rate across seeds (approximately 215 true-priority pairs in an average seed fleet), a top-50 prioritization window captures approximately 25 true pairs under HygienePrio-full (P@50 = 0.509) versus approximately 10 under EPSS-only (P@50 = 0.202) in this synthetic evaluation. The additional 15 pairs per maintenance window represent a substantial synthetic improvement—but whether this translates to real fleet operational impact requires prospective evaluation.

Failure mode analysis. HygienePrio-full outperforms EPSS-only on all 25 evaluation seeds, so there are no seeds in this evaluation where EPSS-only is preferred. However, the improvement is not uniform: the per-seed P@50 improvement ranges from $\approx$0.18 to $\approx$0.44 (from Fig. 2). Seeds with smaller improvements likely represent fleet configurations where patch debt is more uniformly distributed (reducing HRS's discriminative power) or where EPSS scores cluster narrowly (reducing the interaction term's relevance). Identifying which fleet characteristics predict smaller benefits from HygienePrio is an important direction for sensitivity analysis on real data.

E. Limitations

Synthetic data. All results are from a synthetically generated fleet using structural priors from public sources (DBIR, NVD, CISA BOD). The synthetic fleet cannot capture the full heterogeneity of real enterprise environments. Results should not be interpreted as predictions for real fleet prioritization without external validation.

Ground truth circularity. The ground truth definition includes HRS > 75th percentile as a labelling condition (§3). This creates a structural advantage for methods that incorporate HRS. The pre-registration prevents post-hoc optimization, but independent ground truth from real exploitation outcomes would provide a circularity-free evaluation.

Calibration instability. Weight calibration on only 5 seeds (held out from 30 total) is a thin calibration set given the observed seed-to-seed variance. The calibrated weights $(\alpha, \beta, \gamma, \delta)$ may not generalize robustly. A larger calibration set would reduce calibration noise.

Scorer linearity. The HygienePrio scorer is a linear combination with one interaction term. Non-linear relationships between hygiene dimensions and remediation priority that may exist in real fleets are not captured.

False positive cost. P@K does not account for the operational cost of acting on a false positive. Wasted remediation capacity directed at a non-priority pair is not merely neutral—it displaces another pair from the maintenance window. A metric that weights false positives by remediation cost would provide a more operationally realistic assessment.

IX. Threats to Validity

This section follows the four-category taxonomy of Wohlin et al. [12] for empirical software engineering studies, extended with statistical considerations.

A. Conclusion Validity

Statistical method. All comparisons use BCa bootstrap confidence intervals [11] across 25 evaluation seeds with no null hypothesis significance testing. Evidence is based on CI non-overlap, which is a conservative but defensible criterion. A limitation of this approach is that CIs can overlap while a permutation test would reject the null—we err on the side of requiring non-overlap for a claim of substantive evidence.

Multiple comparisons. Results for nine methods at three K values and two metrics (P@K, NDCG@K) constitute 54 comparisons. No familywise or false discovery rate correction is applied; all comparisons are pre-registered and the paper's primary claims are limited to the largest, most stable differences (HygienePrio-full vs. EPSS-only, $\geq$21 pp at all K). Smaller differences (interaction term, freshness dimension) are explicitly treated as equivocal.

Seed budget. With 25 evaluation seeds, the bootstrap CIs have limited resolution. Differences of $<\approx$3 pp are unlikely to be distinguishable from seed-to-seed variation (estimated from the within-seed variance of the most stable comparisons). All headline claims involve differences substantially larger than this threshold ($\geq$21 pp). The 5-seed calibration set is thin; weight calibration on 5 seeds may produce noisy estimates relative to the true optimal weights.

Bootstrap variance. The BCa CI computation uses 10,000 bootstrap resamples per comparison. For a 25-seed evaluation, bootstrap variance in CI boundaries is small relative to the observed differences. The BCa procedure corrects for bias and skewness in the bootstrap distribution, making it preferable to the percentile bootstrap for skewed P@K distributions.

B. Internal Validity

Synthetic data generation. The EEHDA fleet generator uses structural priors (DBIR patch-lag statistics, NVD severity distributions) that represent population-level aggregates. If real fleets deviate substantially from these priors—for example, if patch debt is correlated with host criticality in ways not modeled—results may not replicate.

Ground truth circularity. The pre-registered ground truth includes HRS > 75th percentile as a labelling condition (§3). This provides a structural advantage to HygienePrio over baselines that do not incorporate HRS. The threshold (75th percentile) was fixed before evaluation, preventing post-hoc optimization, but the choice of this specific threshold is not externally validated. Results under the 60th or 90th percentile threshold are not reported; sensitivity to this choice is an open question.

Threshold choices. The EPSS > 0.10 and HRS > 75th percentile thresholds that define the positive class are operationally motivated but not derived from validated exploitation data. These thresholds directly control the base rate of true positives (6.2% mean across seeds) and therefore affect P@K values for all methods. The relative ordering of methods may be less sensitive to threshold choice than the absolute P@K values, but this is not verified.

Calibration leakage. Calibration and evaluation seeds are strictly separated (5 calibration, 25 evaluation, from adjacent seed values). If the generator has strong autocorrelation across adjacent seed values, the calibration/evaluation separation may be partially compromised. Generator analysis supporting independence of adjacent seeds is not reported; this is a known limitation.

Measurement validity of HRS dimensions. PatchPosture is measured as a static snapshot of the proportion of applicable CVEs that remain unpatched. This does not capture patch scheduling latency: a host may have 50% unpatched CVEs today with all patches scheduled for tomorrow. In real environments, operational scheduling context would be needed to distinguish genuine neglect from planned maintenance.

C. External Validity

Generalizability to real enterprise fleets. The synthetic fleet cannot replicate the diversity of real enterprise environments. All results are bounded to the synthetic evaluation context. Claims about real-fleet performance require studies on real fleet data with appropriate institutional approvals and privacy protections.

Generalizability across sectors. The EEHDA generator is calibrated for government-shaped public-sector fleet characteristics (following Paper 1). Commercial enterprise, healthcare, and critical infrastructure fleets may have substantially different hygiene posture distributions, making the specific calibrated weights inapplicable without recalibration.

Temporal validity. EPSS scores change daily. The evaluation uses a fixed snapshot per seed. In a production deployment, HygienePrio would use daily-updated EPSS scores; the evaluation captures only one temporal cross-section per seed, which may not reflect the distribution of daily prioritization decisions over time.

D. Construct Validity

HRS as a proxy for real risk. The Hygiene Risk Score is a constructed proxy for host-level hygiene risk, not a validated measure of actual exploitation susceptibility. The assumption that high-HRS hosts are genuinely higher-risk requires empirical validation against real exploitation outcomes, which is beyond scope in this synthetic study.

Dimension underrepresentation. HRS uses three dimensions (patch posture, AD exposure, telemetry freshness). Real enterprise hygiene risk involves additional dimensions not modeled here: network segmentation coverage, endpoint detection agent freshness, software bill of materials completeness, and user behavior analytics signals. The three-dimension HRS may systematically underestimate risk for certain host archetypes (e.g., network-isolated hosts with good patch posture but no EDR coverage).

P@K as a remediation metric. Precision@K assumes equally valuable true positives. In real operations, some (host, CVE) pairs may be substantially more consequential than others (e.g., domain controllers vs. user workstations), and a severity-weighted metric might yield different method rankings. Oracle-gap captures ceiling relative to the positive base rate but shares the binary relevance limitation.

Scorer linearity. The linear scorer with one interaction term may not capture complex non-linear relationships between hygiene dimensions and actual exploitation risk in real fleets.

X. Related Work

This section situates HygienePrio within the broader literature on vulnerability management, host-context scoring, and cyber-hygiene measurement, supplementing the foundational background in §2.

Vulnerability scoring and exploit prediction. The Common Vulnerability Scoring System (CVSS) [13] provides a standardised framework for assessing severity across Base, Temporal, and Environmental metrics. As a CVE-level signal, CVSS shares the asset-agnostic limitation of EPSS [1]: it scores a vulnerability in isolation without regard to the maintenance state of the affected host. Jacobs et al. [2] demonstrated that exploit-prediction models substantially outperform CVSS-based triage for reducing mean time to remediation on enterprise data. This foundational result motivates using EPSS as the primary exploit-likelihood signal in HygienePrio. The National Vulnerability Database (NVD) [14] serves as the primary aggregation point for CVSS scores and CVE metadata. Unlike the above work, which optimises exploit prediction as a standalone CVE-level signal, HygienePrio integrates exploit likelihood with host-level hygiene posture via an explicit interaction term, targeting the (host, CVE) pair rather than the CVE alone.

Risk-based vulnerability management (RBVM). Commercial RBVM platforms—Tenable Lumin, Qualys TruRisk, and Rapid7 InsightVM—combine EPSS, CVSS, threat intelligence, and asset context in proprietary scoring models that address the same host-CVE pair prioritization problem as HygienePrio. These systems are closed and not independently reproducible; no comparison claims are made against them. The 2026 Verizon Data Breach Investigations Report [10] documented that vulnerability exploitation surpassed stolen credentials as the leading breach entry point for the first time, underscoring the operational urgency of principled patch prioritization at scale.

Capacity-constrained prioritization. Paper 1 [5] constructed a reproducible benchmark for (host, CVE) pair prioritization on a synthetic government-shaped fleet, evaluating thirteen strategies combining EPSS, CVSS, KEV membership, asset criticality, and endpoint exposure across thirty seeds. Its central finding was null: no CVE-level augmentation materially outperformed EPSS, attributing this to uncalibrated weights and the absence of host-level hygiene signals. HygienePrio directly addresses this gap by introducing a three-dimensional Hygiene Risk Score.

Identity and access management (IAM) security. The foundational concepts of access control and identity state that underpin the Active Directory (AD) Exposure dimension of HRS are surveyed in Bertino & Sandhu [15]. AD-exposure-aware risk scoring has been proposed in the lateral movement risk literature; HygienePrio incorporates AD exposure as one of three HRS dimensions, operationalizing domain-privilege exposure as a host-level risk amplifier rather than as a standalone signal.

Anomaly detection for hygiene monitoring. Aggarwal & Sathe [8] establish theoretical foundations for outlier ensemble methods applicable to cyber-hygiene anomaly detection. HygieneBench (Paper 3) [6] applied eight such methods across seven hygiene monitoring tasks on a synthetic fleet, finding that rule baselines dominate 86.2% of configurations but that patch-vulnerability hygiene (Task T5) and group-membership drift (Task T2) are exceptions where structured methods add meaningful signal. HygienePrio operationalises these two discriminative dimensions—patch posture and AD exposure—as the dominant components of HRS, grounded in HygieneBench's empirical findings.

Telemetry freshness and policy mandates. CISA BOD 23-01 [4] mandates 14-day asset discovery and 72-hour vulnerability data freshness for federal agencies, and NIST SP 800-53 [16] specifies continuous monitoring controls that depend on current telemetry. These policies encode the intuition that stale telemetry degrades risk assessment reliability. HygienePrio models telemetry freshness explicitly as the TelemetryFreshness component of HRS, formalizing the policy mandate as a quantitative host-level risk signal.

Weight calibration methodology. The pre-registered evaluation design, seed-stratified BCa bootstrap confidence intervals [11], and capacity-constrained scheduler are inherited from Paper 1 [5]; the calibration gate methodology is inherited from Paper 2. The threats taxonomy follows Wohlin et al. [12].

No prior work combines exploit-likelihood scoring with a multi-dimensional, telemetry-derived host hygiene score and an explicit interaction term in a pre-registered, reproducible evaluation on a synthetic fleet. HygienePrio is the first system to jointly operationalise patch posture, AD exposure, and telemetry freshness as a unified HRS integrated with EPSS for (host, CVE) pair prioritization.

XI. Conclusion

The central finding of this paper is that host-level hygiene posture — patch debt, AD privilege exposure, and telemetry freshness — adds substantial prioritization value over EPSS-only rankings when operationalized as a Hygiene Risk Score and integrated into a pre-calibrated weighted scorer. In a pre-registered synthetic evaluation on the EEHDA fleet, HygienePrio-full outperforms EPSS-only by 31 pp at P@50 across all 25 of 25 evaluation seeds (non-overlapping BCa 95% CIs; synthetic evaluation). The practical take-home message is concrete: of the three hygiene dimensions, patch posture alone accounts for $\approx$20 pp of this improvement. Operations teams with limited instrumentation capacity should prioritize patch posture tracking above more complex hygiene signals such as AD group exposure or telemetry freshness monitoring.

This result completes a three-paper methodological arc. Paper 1 (VulnPrio) established that CVE-level feature augmentation does not improve over EPSS-only, explicitly attributing the null to the absence of dynamic host-level signals. Paper 3 (HygieneBench) demonstrated that patch posture and AD group drift carry discriminative structure in fleet telemetry. HygienePrio operationalizes these signals in a remediation prioritization scorer. The progression from honest null through diagnostic signal identification to positive integration result illustrates how pre-registered negative results generate scientific value by constraining and directing subsequent work.

All results are bounded to the synthetic evaluation context. The ground truth definition incorporates HRS as a labelling condition, creating a structural advantage for HygienePrio that real-exploitation-data evaluation would remove. The calibrated weights were estimated on five synthetic seeds and may not transfer to real fleet distributions. These limitations are inherent to a simulation study; they frame the result as a pre-clinical finding rather than a deployment recommendation.

Reproducibility. The evaluation code, synthetic fleet generator, frozen results, and pre-registration protocol are available in the accompanying repository at https://github.com/Harshavardhanmalla-Labs/research-papers/tree/main/paper4.

Future work. The most important next step is evaluation on real, appropriately anonymized fleet telemetry using exploitation event logs (not HRS) as ground truth. Secondary directions include: (i) extending HRS with network-layer signals (firewall coverage, internet-facing service flags) to test whether additional dimensions contribute beyond the current three; (ii) evaluating HygienePrio under rolling daily EPSS score updates rather than static per-seed snapshots; and (iii) testing whether nonlinear scoring functions trained on historical remediation outcomes can outperform the pre-calibrated linear scorer, which is the binding simplification assumption of this work.

References

[1] J. Jacobs, S. Romanosky, B. Edwards, M. Roytman, and I. Adjerid, "Exploit prediction scoring system (EPSS)," Digital Threats: Research and Practice, vol. 2, no. 3, pp. 14:1–14:17, 2021.

[2] J. Jacobs, S. Romanosky, I. Adjerid, and W. Baker, "Improving vulnerability remediation through better exploit prediction," Journal of Cybersecurity, vol. 6, no. 1, p. tyaa015, 2020.

[3] CISA, "Binding operational directive 22-01: Reducing the significant risk of known exploited vulnerabilities," U.S. Cybersecurity and Infrastructure Security Agency, Nov. 2021. [Online]. Available: https://www.cisa.gov/binding-operational-directive-22-01

[4] ——, "Binding operational directive 23-01: Improving asset visibility and vulnerability detection on federal networks," U.S. Cybersecurity and Infrastructure Security Agency, Oct. 2022. [Online]. Available: https://www.cisa.gov/binding-operational-directive-23-01

[5] H. Malla, "Context-aware vulnerability prioritization for government endpoint fleets: Integrating exploit intelligence, asset criticality, and endpoint telemetry," 2026, manuscript on file; arXiv / submission DOI to be added at camera-ready.

[6] ——, "HygieneBench: A reproducible synthetic benchmark for cyber-hygiene anomaly detection across identity, endpoint, and patch telemetry," 2026, manuscript on file; arXiv / submission DOI to be added at camera-ready.

[7] CISA, "Known exploited vulnerabilities (KEV) catalog," U.S. Cybersecurity and Infrastructure Security Agency, accessed May 2026. [Online]. Available: https://www.cisa.gov/known-exploited-vulnerabilities-catalog

[8] C. C. Aggarwal and S. Sathe, "Theoretical foundations and algorithms for outlier ensembles," ACM SIGKDD Explorations Newsletter, vol. 17, no. 1, pp. 24–47, 2015.

[9] NIST, "Guide to enterprise patch management planning: Preventive maintenance for technology," National Institute of Standards and Technology, Tech. Rep. Special Publication 800-40 Rev. 4, Apr. 2022. [Online]. Available: https://doi.org/10.6028/NIST.SP.800-40r4

[10] Verizon, "2026 data breach investigations report (DBIR)," Verizon Business, Tech. Rep., 2026. [Online]. Available: https://www.verizon.com/business/resources/reports/dbir/

[11] B. Efron and R. J. Tibshirani, An Introduction to the Bootstrap. Chapman & Hall/CRC, 1994.

[12] C. Wohlin, P. Runeson, M. Höst, M. C. Ohlsson, B. Regnell, and A. Wesslén, Experimentation in Software Engineering. Springer, 2012.

[13] FIRST.org, "Common vulnerability scoring system v3.1 specification document," Forum of Incident Response and Security Teams, Tech. Rep., 2019. [Online]. Available: https://www.first.org/cvss/specification-document

[14] NIST, "National vulnerability database (NVD)," National Institute of Standards and Technology, accessed May 2026. [Online]. Available: https://nvd.nist.gov

[15] E. Bertino and R. Sandhu, "Database security—concepts, approaches, and challenges," IEEE Transactions on Dependable and Secure Computing, vol. 2, no. 1, pp. 2–19, 2005.

[16] NIST, "Security and privacy controls for information systems and organizations," National Institute of Standards and Technology, Tech. Rep. Special Publication 800-53 Rev. 5, Sep. 2020. [Online]. Available: https://doi.org/10.6028/NIST.SP.800-53r5